



SSL/TLS. Let's encrypt, Certbot



WHAT IS HTTPS

HTTP PROTOCOL + SECURITY

- SSL/TLS (Secure Sockets Layer / Transport Layer Security)
- keeps your passwords, communications, and credit card details safe between your computer and the servers you're communicating with on the other side.
- still speaking in HTTP, but the communication is encrypted and decrypted

HOW DOES IT WORK?

HELLO —> CERTIFICATE EXCHANGE —> KEY EXCHANGE

1. ClientHello message

- aka the information the server needs to connect to the client via SSL
- server will respond with a ServerHello i.e. similar info including the cipher suite and version of SSL to be used

2. Certificate Exchange

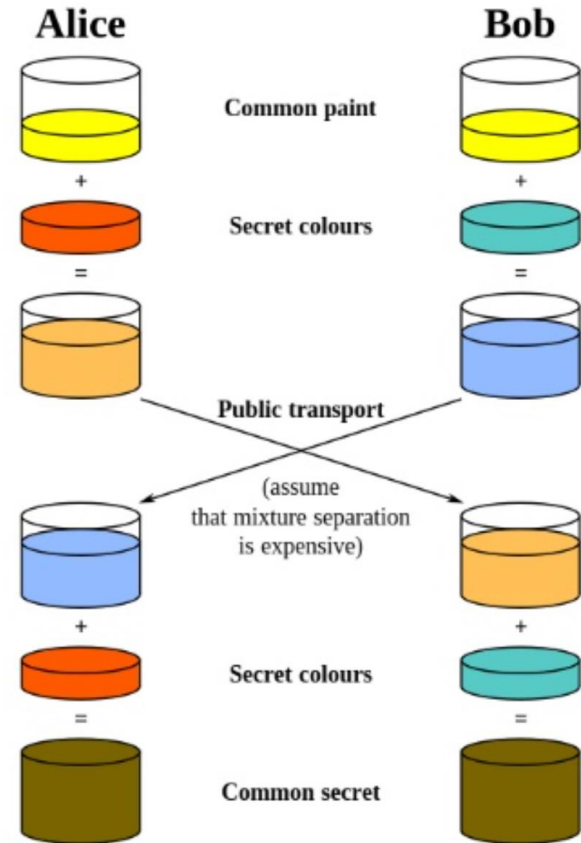
- the server needs to prove its identity via its SSL certificate*
- does it either (a) implicitly trust or (b) is it verified by one of many CAs

3. Key Exchange

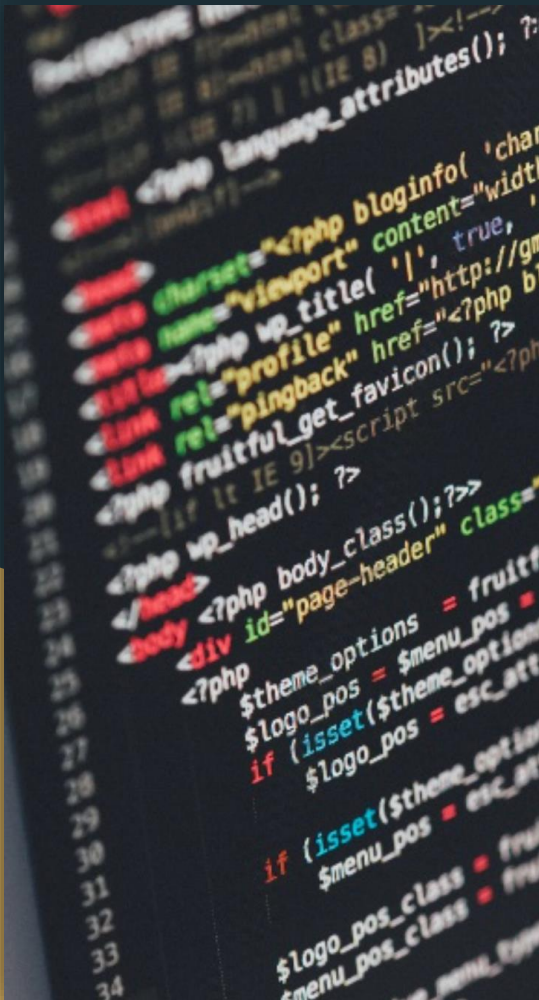
- Encryption via a symmetric algorithm using a single key * the client may also need to prove its identity, but not always

WHAT'S THE POINT?

- HTTP requests and responses can now be sent through an encrypted plaintext message
- i.e. verifies that you're talking directly to the the server you think you're talking to
- But because only the other side knows how to decrypt this message, Man In The Middle Attackers are unable to read or modify any requests that they may intercept.
- i.e. ensures that only that server can read what you send and only you can read what it sends



Diffie-Hellman Key Exchange



WHILST THE LITTLE GREEN PADLOCK AND THE LETTERS “HTTPS” IN YOUR ADDRESS BAR DON’T MEAN THAT THERE ISN’T STILL AMPLE ROPE FOR BOTH YOU AND THE WEBSITE YOU ARE VIEWING TO HANG YOURSELVES ELSEWHERE, THEY DO AT LEAST HELP YOU COMMUNICATE SECURELY WHILST YOU DO SO.

Rob Heaton

SIGNIFICANCE OF SSL

- if you see encrypted traffic today, you can generally assume there is a reason.
- by encrypting everything you give cover to those who need it
- for example political dissidents

HOW DOES SSL WORK?

WHY DOES IT PROTECT SENSITIVE INFORMATION?

1. 2 key encryption

- private key and public key agree on a key for this exchange
- symmetric algorithm with asymmetric encryption
- anyone can encrypt using the public key, but only the server can decrypt using the private key

2. digital signature is “signed” by another authority

3. self-signing

WHAT IS “LET’S ENCRYPT”?

SETUP OF A DOMAIN VALIDATION (DV) CERTIFICATE*

1. Download Let’s Encrypt on your server that has the address `www.oohshinywebsite.com`:

```
sudo apt install lets-encrypt
```

2. You run it as sudo telling it you want to get a certificate for your domain

```
lets-encrypt oohshinywebsite.com
```

* DV Certificate = “the CA checks the right of the applicant to use a specific domain name. No company identity information is vetted and no information is displayed other than encryption information within the Secure Site Seal.” There are other types of certificates with varying requirements.

SO...HOW DO YOU ENCRYPT YOUR SITE?

SHARED HOSTING

- Bluehost
- GoDaddy
- Pantheon
- LiteSpeed
- SiteGround
- Media Temple
- Flywheel
- WP Engine
- DreamHost
- LE's community list

VPS AND OTHER SERVER SETUPS

- **nginx** - <https://www.digitalocean.com/community/tutorials/how-to-secure-nginx-with-let-s-encrypt-on-ubuntu-20-04>
- **Apache** - <https://www.digitalocean.com/community/tutorials/how-to-secure-apache-with-let-s-encrypt-on-ubuntu-20-04>
- **Centos vs Debian/Ubuntu** - <https://www.linode.com/docs/security/ssl/install-lets-encrypt-to-create-ssl-certificates>

COMMON ISSUES

THE BAD

- No wild cards, i.e. difficult in multi/ load-balanced setup
- Renewal every 90 days

THE GOOD

- Easy to setup
- Free to use
- Good for single server setups

COMMON ISSUES

COMMON ISSUES JETPACK

- change WordPress settings
- Dashboard > Settings > General
- site URL
- WordPress URL

GOOGLE SEO

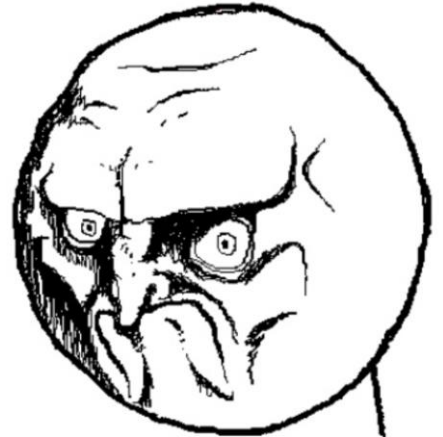
- your search rankings vs any modicum of care you have for your audience



Lets Encrypt!

SSL certificate orders/renewals so far

- Generate RSA key
- Generate CSR
- Log in to CA's web horrible interface
- Fill out certificate order form
- Pay a lot of money
- Verify domain



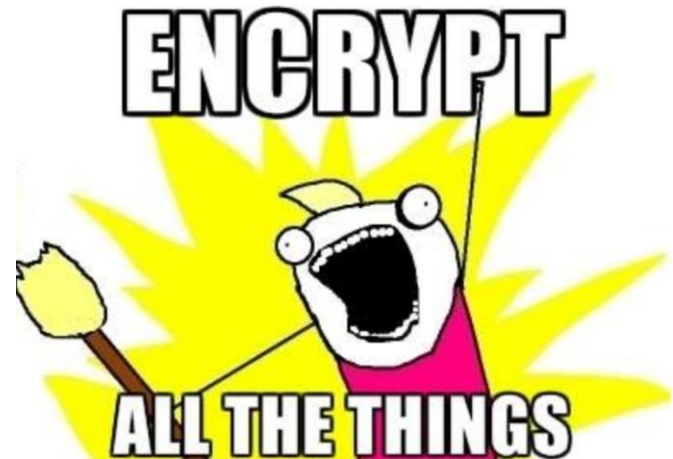
Let's Encrypt

<https://letsencrypt.org/>

- "free, automated, and open certificate authority (CA), run for the public's benefit"
[<https://letsencrypt.org/about/>]
- Provided by ISRG - Internet Security Research Group (California based Non-Profit)
- Sponsored by Mozilla, Akamai, Cisco, EFF, OVH, Facebook, Chrome, etc.
- **Mission:** reduce technological & financial barriers to secure internet communication

What does it do?

- Still with Key, CSR, Domain verification, get certificate
- It's automated
- It's free



How does it work?

- ACME protocol: <https://ietf-wg-acme.github.io/acme/>
- Specifies mostly the process of domain verification
- What we need to know: <https://letsencrypt.org/how-it-works/>
- Server admin is identified by key pair
- CA issues challenges to authorize key pair, e.g.
 - DNS record
 - File on server

Pitfalls

User running letsencrypt must have write access to web server root

Make sure dot-files are accessible

Challenge path: <https://my-domain.com/.well-known/acme-challenge/jd1o3ddZXTYbjwUHvRnQOFC7ToSY-BKxyd6LdFgJvOg>

```
server {  
    listen 80;  
  
    # don't do this  
    location ~ ^/\. {  
        deny all;  
    }  
}
```

Certificates

- Root CA: ISRG Root X1
- Intermediates:
 - Let's Encrypt Authority X1 (not widely supported yet)
 - Let's Encrypt Authority X2 (recovery)
- Cross signed by IdenTrust (DST Root CA X3), widely supported
- Issues certs: <https://www.certificate-transparency.org>
- Searchable: <https://crt.sh/>

Client Support

Yep:

- Android > 2.3.6
- Firefox > 2.0, Firefox OS > 2.2
- Windows: IE, Chrome
- Safari > 4.0, iOS > 3.1
- Linux: Debian > 6, Ubuntu > 12.04, CentOS ?
- Quickly tested:
- Node.js,
- PHP

Nope:

- Java as of jdk8u51 (applied for)
- Older Androids
- Windows XP
- Blackberry

Rate Limits

According to <https://community.letsencrypt.org/t/rate-limits-for-lets-encrypt/6769>

- Domains per certificate: 100 Certificates per domain: 5 certs/domain/week
- Registrations per IP: 500/3hrs
- For testing/development: use staging env (`--test-cert`, `--staging`)
- No limits on total number of certificates

Integrations

- Apache installer (haven't tried)
- Caddy Server
- Express middleware
- Fully automated SSL FTW!

Why should you use it?

- Less work - makes you happy
- It's free - makes your boss/client happy
- It's encrypted - makes your users safer
- It's automated - makes DevOps people happy



Certbot

Certbot

Certbot is part of EFF's effort to encrypt the entire Internet. Secure communication over the Web relies on HTTPS, which requires the use of a digital certificate that lets browsers verify the identity of web servers (e.g., is that really google.com?). Web servers obtain their certificates from trusted third parties called certificate authorities (CAs). Certbot is an easy-to-use client that fetches a certificate from Let's Encrypt—an open certificate authority launched by the EFF, Mozilla, and others—and deploys it to a web server.

Anyone who has gone through the trouble of setting up a secure website knows what a hassle getting and maintaining a certificate is. Certbot and Let's Encrypt can automate away the pain and let you turn on and manage HTTPS with simple commands. Using Certbot and Let's Encrypt is free, so there's no need to arrange payment.

Certbot

How you use Certbot depends on the configuration of your web server. In most cases, you'll need root or administrator access to your web server to run Certbot.

Certbot is meant to be run directly on your web server, not on your personal computer. If you're using a hosted service and don't have direct access to your web server, you might not be able to use Certbot. Check with your hosting provider for documentation about uploading certificates or using certificates issued by Let's Encrypt.

Certbot is a fully-featured, extensible client for the Let's Encrypt CA (or any other CA that speaks the ACME protocol) that can automate the tasks of obtaining certificates and configuring web servers to use them. This client runs on Unix-based operating systems.

How to run the client

The easiest way to install and run Certbot is by visiting certbot.eff.org, where you can find the correct instructions for many web server and OS combinations.

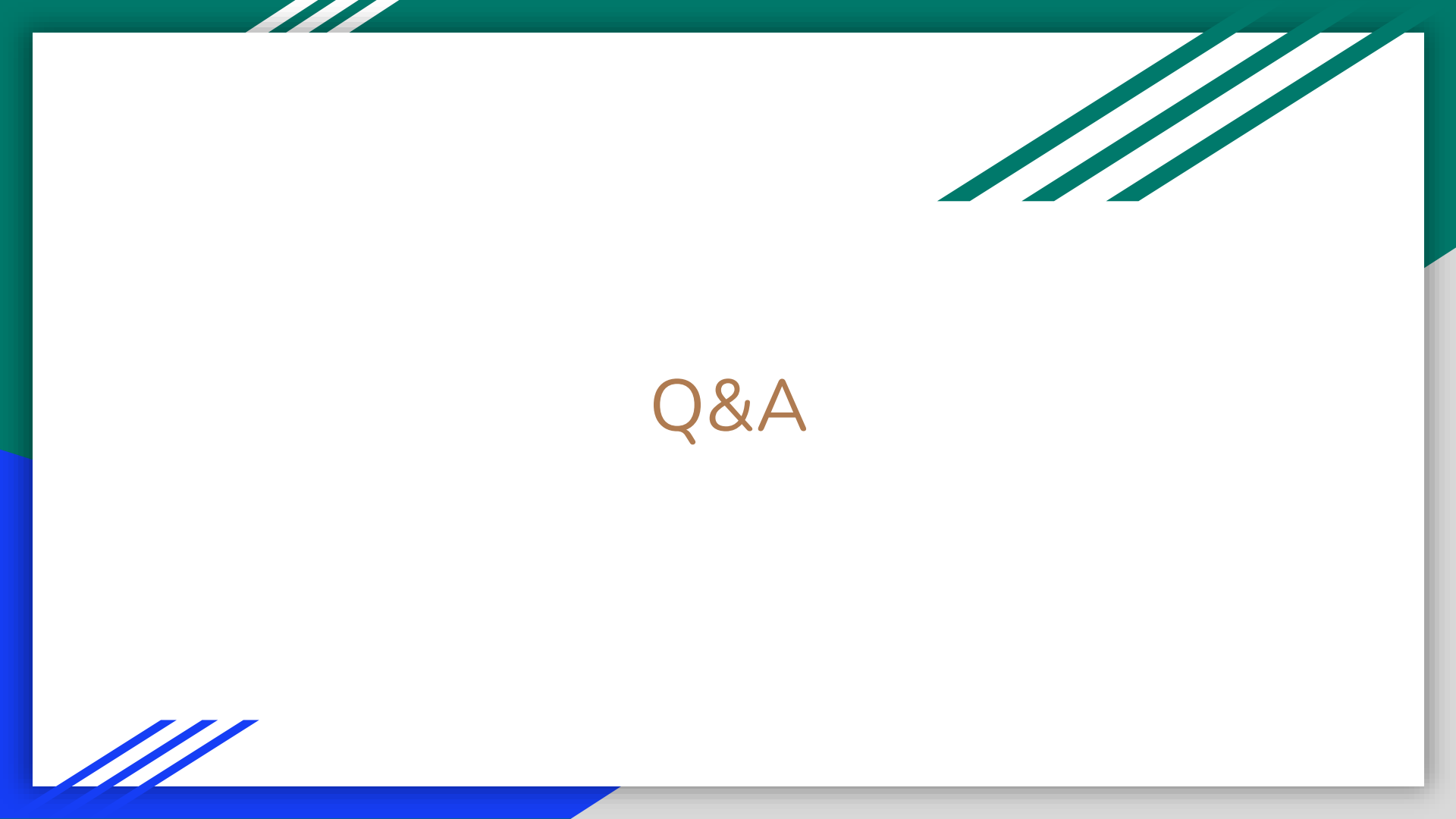
Certbot currently requires Python 2.7 or 3.6+ running on a UNIX-like operating system. By default, it requires root access in order to write to `/etc/letsencrypt`, `/var/log/letsencrypt`, `/var/lib/letsencrypt`; to bind to port 80 (if you use the standalone plugin) and to read and modify webserver configurations (if you use the apache or nginx plugins). If none of these apply to you, it is theoretically possible to run without root privileges, but for most users who want to avoid running an ACME client as root, either `letsencrypt-nosudo` or `simp_le` are more appropriate choices.

The Apache plugin currently requires an OS with `augeas` version 1.0; currently it supports modern OSes based on Debian, Ubuntu, Fedora, SUSE, Gentoo and Darwin.

Understanding the client in more depth

Plugin	Auth	Inst	Notes	Challenge types (and port)
apache	Y	Y	Automates obtaining and installing a certificate with Apache.	http-01 (80)
nginx	Y	Y	Automates obtaining and installing a certificate with Nginx.	http-01 (80)
webroot	Y	N	Obtains a certificate by writing to the webroot directory of an already running webserver.	http-01 (80)
standalone	Y	N	Uses a "standalone" webserver to obtain a certificate. Requires port 80 to be available. This is useful on systems with no webserver, or when direct integration with the local webserver is not supported or not desired.	http-01 (80)
DNS plugins	Y	N	This category of plugins automates obtaining a certificate by modifying DNS records to prove you have control over a domain. Doing domain validation in this way is the only way to obtain wildcard certificates from Let's Encrypt.	dns-01 (53)
manual	Y	N	Helps you obtain a certificate by giving you instructions to perform domain validation yourself. Additionally allows you to specify scripts to automate the validation task in a customized way.	http-01 (80) or dns-01 (53)

ins.



Q&A